

AI攻撃エージェント 防御ダッシュボード

Defensive dashboard for offensive AI agents — 攻撃連鎖の俯瞰と検知カバレッジ（オフライン・ローカル完結）

🌑 テーマ切替

① 攻撃エージェント マップ

② 検知カバレッジ

③ 予防コントロール

④ CVP 対応

⑤ リポジトリ資産

① 攻撃用AIエージェント マップ Landscape

Gambit の 3 ツールは「分業チェーン型」の一例。タイプで整理すると防御の当てはめが見通せる。悪用報告/疑い は注意喚起。

① 分業チェーン型 Division-of-labor chain（Gambit の事例）

役割を別ツールで分担（統括 / 偵察 / 侵入）

Hermes 統括・事後

Strix 偵察・脆弱性

Cairn 自律侵入

④ E2E 自律ペンテスト型 End-to-end autonomous

偵察～実行～検証を単体で完結（多くはマルチエージェント・Kali コンテナ）

PentAGI

Villager 悪用

ARTEX AI 疑い

NeuroSploit

PentestAgent

Pentest-Swarm

Decepticon

Shannon

hackingBuddyGPT

⑤ 攻撃基盤・フレームワーク型 Attack framework

エージェントに多数ツールを持たせる土台（MCP 等で 150+ ツール統括）

HexStrike AI 悪用

CAI

TARS

⑥ 対話型アシスタント型 Interactive assistant

人が主導し AI が提案/実行支援（自律モードを持つ物も）

PentestGPT

Pentest Copilot

類型整理は 三輪信雄氏(@NobMiwa) の公開まとめを参照。個別ツールの分類・能力は変化するため挙動ベースで扱う。

② 検知カバレッジマトリクス Detection coverage

タイプ別チップを押すと、その型に効く検知行がハイライトされます。検知の土台は共通（LLM推論・スキャン・ツール実行・C2）なので R1-R7 が横展開で効きます。

① 分業チェーン

④ E2E

⑤ 基盤

⑥ アシスタント

すべて表示

ID	検知 / Signal	データソース	優先度	①	④	⑤	⑥
R1	サーバ系→外部LLM API への egress	proxy / DNS / NetFlow	高	●	○	○	—
R2	特権cap / host net / privileged コンテナ起動	container audit / Falco	中	●	●	●	—
R3	管理画面パス列挙バースト（4xx多発）	web / WAF	中	●	●	●	○
R4	サーバ→メッセージングAPI（C2 的）	proxy / DNS	高	●	—	—	—
R5	永続化（cron / systemd）の新規作成	host (auditd/sysmon)	中	●	○	—	—
R7	1親プロセスが多種セキュリティツールを短時間連続実行 ローカルLLM型でも残る“挙動の核”	EDR / process telemetry	高	●	●	●	○
R6	相関（R3 + R1 + (R2 or R7) + 任意 R4/R5）	SIEM 相関	高	●	●	●	○

● 主に効く ○ 条件付き/補助 — 低適用 優先度 高 中 低

勘所：ローカルLLM対応型（PentAGI/Villager 等）は R1(egress) を回避できる → R7（多ツール連続実行）と R2（コンテナ）に重心。基盤型（HexStrike = MCPで多ツール統括）も R7 が核。

③ 予防コントロール Preventive controls

検知の前段で効く固定策。優先度順。

- 送信ドメイン **allowlist** — サーバ系からの LLM/メッセージングは既定遮断。
- コンテナ **admission control** — 特権cap・host net・未署名/未知イメージを禁止。
- 攻撃面最小化 — 管理画面の隔離、DB/サービスをネット直結にしない（`netcheck` の RISKY ポート群）。
- 決済・機微ページの **CSP** — skimmer/カード窃取コード注入の防止。

- LLM 利用の監査・ガバナンス — 安全機構の除去/迂回の試行を検知・通報。

④ CVP (Cyber Verification Program) 対応 Anthropic

活動をどのティアで正規化するか。詳細は `cvp-readiness.md`。

Defense Access 防御 (SOC/IR/マルウェア解析/脆弱性検証)。個人研究者も可・審査数日。本リポの防御ツール + 解析 + 検知ルールが射程。

Red Team Access 認可されたペンテスト (組織のみ・数週間)。Cairn ラボ運用はここ。隔離設計・ランブック・mock検証が統制証拠。

Specialized Access 安全重要システム (電力/通信/金融/政府網)。米政府連携が必要。

不変の一線：物理被害・大規模妨害・ランサム・安全系無効化はブロック対象。

⑤ リポジトリ資産 Repository assets

防御ツール

- `vuln_triage.html` — スキャナ結果のトリアージ
- `netcheck/` — 確認専用チェック (攻撃なし)
- `scripts/summarize.py` — 結果集計
- `.github/workflows/security-scan.yml` — CI (Semgrep/Trivy/gitleaks)

解析・設計

- `defense-detection-notes.md` — 防御・検知ノート (R1-R7)
- `detections/` — Sigma / Falco / Datadog ルール
- `strix-local-backend-notes.md` + `strix-local-poc/`
- `cairn-lab/` — 認可ラボ・ランブック + 実設定

CVP

- `cvp-readiness.md` — ティア対応・申請準備
- `cvp-package/` — 申請パッケージ (HTML/PDF)

このダッシュボード

- dashboard.html ー 本ファイル (オフライン・ローカル完結)
- ブラウザで開くだけ。外部通信なし。

検知・防御の設計に限定。攻撃の実行手順や安全機構の回避方法は含めない。出典は各 md を参照。